

1. Install and run the free version of the OpenVAS or Nessus vulnerability scanner on your system, and perform a basic scan of your own computer or a local virtual machine.

The screenshot displays the Tenable Nessus Essentials web interface. The main header shows 'tenable Nessus Essentials' and navigation tabs for 'Scans' and 'Settings'. The user 'Rohan23' is logged in. On the left sidebar, there are sections for 'FOLDERS' (My Scans, All Scans, Trash) and 'RESOURCES' (Policies, Plugin Rules). The main content area is titled 'Windows PC Vulnerability Scan' and includes a 'Back to My Scans' link. Below this, there are tabs for 'Hosts' (1), 'Vulnerabilities' (23), 'Notes' (1), and 'History' (2). A search bar and a table of hosts are visible. The table has columns for 'Host', 'Auth', and 'Vulnerabilities'. One host, '192.168.1.132', is listed with a 'Fail' status and a vulnerability score of 70. To the right, the 'Scan Details' section shows: Policy: Basic Network Scan, Status: Completed, Severity Base: CVSS v3.0, Scanner: Local Scanner, Start: Today at 10:30 AM, End: Today at 10:37 AM, and Elapsed: 7 minutes. Below this is a 'Vulnerabilities' section with a donut chart showing the distribution of severity levels: Critical (red), High (orange), Medium (yellow), Low (green), and Info (blue).

2. Scan your Wi-Fi router's IP address using Nmap and list all open ports detected.

```
(kali@kali)-[~]
└─$ nmap -v 192.168.1.1
Starting Nmap 7.99 ( https://nmap.org ) at 2020-09-25 04:15 -0400
Initiating ARP Ping Scan at 04:15
Scanning 192.168.1.1 [1 port]
Completed ARP Ping Scan at 04:15, 0.06s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 04:15
Completed Parallel DNS resolution of 1 host. at 04:15, 0.04s elapsed
Initiating SYN Stealth Scan at 04:15
Scanning RTK_GW.bbrouther (192.168.1.1) [1000 ports]
Discovered open port 443/tcp on 192.168.1.1
Discovered open port 445/tcp on 192.168.1.1
Discovered open port 53/tcp on 192.168.1.1
Discovered open port 23/tcp on 192.168.1.1
Discovered open port 80/tcp on 192.168.1.1
Discovered open port 21/tcp on 192.168.1.1
Completed SYN Stealth Scan at 04:15, 0.47s elapsed (1000 total ports)
Nmap scan report for RTK_GW.bbrouther (192.168.1.1)
Host is up (0.0024s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
23/tcp    open  telnet
53/tcp    open  domain
80/tcp    open  http
443/tcp   open  https
445/tcp   open  microsoft-ds
MAC Address: 68:31:92:16:8C:45 (OVT India pvt)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.65 seconds
Raw packets sent: 1001 (44.028KB) | Rcvd: 1001 (40.052KB)

(kali@kali)-[~]
```

3. Analyze the scan report from your vulnerability scanner and identify at least 3 vulnerabilities or warnings it reports; for each, write a one-line description of what the risk is.

No	Vulnerability	Risk Description
1	SSL	SSL-related security issues may weaken encrypted communication and could expose data to interception or other attacks.
2	SMB	SMB configuration issues may expose Windows file-sharing services and increase the risk of unauthorized access or information disclosure.
3	HTTP	Issues with the HTTP service may expose the web service to security weaknesses or information disclosure.
4	TLS	Weak or outdated TLS configurations can reduce the security of encrypted network communications.

- 4. Pick any app you use daily (like Instagram, Zomato, or Paytm) and research one real vulnerability that was found in it in the past; write a short summary of what the vulnerability was and how it could have been detected by scanning tools.**

App – Zomato

Vulnerability – SQL injection

- A real SQL injection vulnerability was reported in Zomato's web application through its HackerOne bug-bounty program. The vulnerability involved an input parameter that could be manipulated in a way that allow SQL commands to be injected into a database query. If exploited, SQL injection can potentially expose, modify or retrieve unauthorized database information. Zomato's bug-bounty records show multiple SQL injection reports including SQLi affecting web application parameters.

How scanning tools could detect it

- Tools such as Nessus, OpenVAS/Greenhouse, Burp suite and OWASP ZAP can help to identify SQL injection by testing application inputs and looking for abnormal database responses or known vulnerable patterns. Automated scanners can flag potentially injectable parameters while tools such as Burp Suite can be used for further authorized testing and validation.

Risk

- An SQL Injection vulnerability can lead to unauthorized database access, data disclosure, data modification or authentication bypass depending on the application's configuration.

- [illegible]